Environment variables

The backend reads settings through `backend/app/core/config.py` (Pydantic `BaseSettings`). Values come from the process environment, then from `backend/.env`. The env file path is **relative to the working directory**, so start `uvicorn`, `celery`, `alembic` and `pytest` from `backend/`. Names are case-insensitive. Copy `backend/.env.example` to `backend/.env`; never commit `.env`.

Required below means "the pipeline does not work without it", not "the process refuses to start" — most services are built lazily, so a missing value surfaces when first used.

Backend — required for a working local pipeline

Variable	Default	Purpose	Where to get it	If missing
`DATABASE_URL`	`postgresql+psycopg2://docauth:docauth@localhost:5432/docauth`	The **owner** connection — used only by Alembic and `seed.py` (needs CREATEROLE, not superuser). Its host/port/database are also used for the two app roles below	Matches the Postgres in `docker-compose.yml` (default works as-is)	Migrations fail; API/worker can't build their URLs
`DATABASE_APP_USER` / `DATABASE_APP_PASSWORD`	`fddt_app` / `fddt_app_local`	The role every company request and pipeline task connects as (NOBYPASSRLS — Row-Level Security applies). The migration creates it with this password	Choose a long random password **before** running `alembic upgrade head`	Every request fails to connect
`DATABASE_PLATFORM_USER` / `DATABASE_PLATFORM_PASSWORD`	`fddt_platform` / `fddt_platform_local`	The role for sign-in, platform-admin screens and usage reconciliation (all rows through the `platform_all` policy; no BYPASSRLS)	Same	Login and platform screens fail
`CELERY_BROKER_URL`	`redis://localhost:6379/0`	Celery broker	The Redis in `docker-compose.yml`	Uploads succeed but nothing is processed; documents stay `pending`
`CELERY_RESULT_BACKEND`	`redis://localhost:6379/1`	Celery results	Same Redis, DB 1	Worker errors on result storage
`JWT_SECRET_KEY`	`changeme-in-.env`	Signs access tokens (HS256)	Generate a long random string, e.g. `python -c "import secrets; print(secrets.token_urlsafe(48))"`	Outside `ENVIRONMENT=local/dev/test` the API **refuses to start** with the default or anything under 32 characters; changing it logs everyone out
`AZURE_STORAGE_CONNECTION_STRING`	*(none)*	Blob Storage account for originals, signature crops and reports	Azure portal → Storage account → *Access keys* → connection string	Upload and file-url endpoints return **503** with an explanatory message

Variable	Default	Purpose	Where to get it	If missing
`AZURE_STORAGE_CONTAINER_NAME`	`documents`	Blob container (must be **private**)	Create it in the storage account	Uploads fail
`AZURE_DOCUMENT_INTELLIGENCE_ENDPOINT`	*(none)*	OCR/layout (`prebuilt-layout`)	Azure portal → Document Intelligence resource → *Keys and Endpoint*	Every document ends `failed` at extraction
`AZURE_DOCUMENT_INTELLIGENCE_KEY`	*(none)*	Same	Same	Same
`AZURE_OPENAI_KEY`	*(none)*	Classification, extraction, issuer semantic match, visual review, signature detect/compare	Azure portal (or AI Foundry) → your OpenAI resource → *Keys*	Extraction fails (document `failed`); visual review/signature checks fail
`AZURE_OPENAI_ENDPOINT`	*(none)*	Resource endpoint. Accepts either `https://<res>.openai.azure.com/` or an AI Foundry project URL `https://<res>.services.ai.azure.com/api/projects/<name>` (normalized to the origin)	Same	Same
`AZURE_OPENAI_DEPLOYMENT_NAME`	*(none)*	The model **deployment** to call. **Must be vision-capable**: its name must contain `gpt-4o` , `gpt-4.1` , `gpt-4-turbo` or `gpt-4-vision` , or the visual review and signature features raise `LLMConfigurationError`	Name you gave the deployment in Azure	Same
`AZURE_OPENAI_MAX_REQUESTS_PER_MINUTE`	`60`	Global cap on Azure OpenAI requests across every worker (Redis limiter). Set to **~80 %** of the deployment's RPM	Azure portal → deployment → *Rate limit*, or the `x-ratelimit-limit-requests` response header	Default 60 may under- or over-shoot your quota (429s or idle capacity)
`AZURE_OPENAI_MAX_TOKENS_PER_MINUTE`	`0` (off)	Global token cap (prompt + `max_tokens` reservation per call). Usually the binding limit. Set to **~80 %** of the deployment's TPM	`x-ratelimit-limit-tokens` header / portal	Without it, bursts exceed TPM → 429s

There is **no local/offline substitute** for storage, OCR or the LLM (no Azurite/mock backend is wired in); a real Azure account is needed to exercise the pipeline. The unit tests mock all three, so they do not call Azure.

Backend — optional / tuning

Variable	Default	Purpose
`ENVIRONMENT`	`local`	Label shown in `/health` and the OpenAPI description

Variable	Default	Purpose
`JWT_ALGORITHM`	`HS256`	JWT algorithm: `HS256`, `HS384` or `HS512` (anything else is refused at startup)
`JWT_ISSUER` / `JWT_AUDIENCE`	`fddt-api` / `fddt-web`	`iss` / `aud` claims, checked on every request
`JWT_ACCESS_TOKEN_EXPIRE_MINUTES`	`15`	Access-token lifetime (1–60). The session lives on through the refresh token
`REFRESH_TOKEN_IDLE_DAYS`	`7`	A sign-in ends after this many days without use
`REFRESH_TOKEN_ABSOLUTE_DAYS`	`30`	A sign-in ends after this many days in any case
`REFRESH_TOKEN_REUSE_GRACE_SECONDS`	`20`	Window in which a just-rotated refresh token is not treated as stolen (two tabs refreshing at once)
`REFRESH_COOKIE_NAME`	`fddt_refresh`	Refresh-token cookie name
`REFRESH_COOKIE_PATH`	`/api/auth`	Browser-visible path of the auth routes; the cookie is sent there only
`REFRESH_COOKIE_SECURE`	`true`	Secure flag on the cookie; keep `true` everywhere (browsers accept it on `http://localhost`)
`API_DOCS_ENABLED`	on, except `ENVIRONMENT=production`	Serve `/docs`, `/redoc`, `/openapi.json`
`AZURE_OPENAI_API_VERSION`	`2024-10-21`	Azure OpenAI REST API version
`AZURE_OPENAI_REQUEST_TIMEOUT_SECONDS`	`60.0`	Per-call LLM timeout. Kept short on purpose: a hung call holds a worker thread (and its rate-limiter reservation)
`AZURE_DOCUMENT_INTELLIGENCE_MAX_CALLS_PER_SECOND`	`10.0`	Global cap on Document Intelligence calls (Azure's default S0 limit is 15 TPS)
`AZURE_DOCUMENT_INTELLIGENCE_STYLE_FONT`	`true`	Request Layout's font-style add-on (`styleFont`), which the font consistency check uses on scanned pages. Billed by Azure as an add-on per page; `false` leaves fonts on scans to the visual review only
`DATABASE_POOLER_HOST` / `DATABASE_POOLER_PORT`	*(unset)* / `6432`	When set, the two app roles connect through **PgBouncer** (transaction pooling) and each process keeps no pool of its own. Recommended in production (processing-queues.md)

Variable	Default	Purpose
`DB_POOL_SIZE` / `DB_MAX_OVERFLOW`	`5` / `10`	SQLAlchemy pool per role per process when connecting **directly** (no PgBouncer)
`DEFAULT_MAX_FILE_SIZE_MB` / `DEFAULT_MAX_ZIP_SIZE_MB`	`10` / `300`	Upload limits a **new** company is created with. Limits are per company (`companies.max_file_size_mb` / `max_zip_size_mb` , changed by a platform admin under Platform › Companies); changing these defaults never changes an existing company. The frontend reads the company's real limits from `GET /auth/me/upload-limits`
`DEFAULT_MAX_FILE_PAGES`	`100`	Page limit per PDF a **new** company is created with (`companies.max_file_pages` , changed by a platform admin like the size limits; `file_too_many_pages` , 413). Forensics renders every page into worker memory at 200 DPI (~11 MB a page), so higher limits need more worker RAM
`BULK_UPLOAD_MAX_ENTRIES`	`25000`	Safety cap on entries (files + folders) in one zip. A 300 MB zip of small born-digital PDFs holds about 11,000 entries
`BULK_UPLOAD_CASE_WARNING_THRESHOLD`	`100`	Above this many cases the UI warns; the zip is still accepted
`DEFAULT_COMPANY_NAME`	`Default Company`	Name of the company the multi-tenancy migration assigns pre-existing data to (used once, by the migration)
`PLATFORM_ACCESS_AUDIT_DEDUP_SECONDS`	`0`	0 = every platform-admin read of company data writes its own (platform-only) audit row; > 0 collapses identical reads within that window
`EXTRACTION_WORKER_CONCURRENCY` / `VISION_WORKER_CONCURRENCY`	`4` / `4`	Threads per extraction / vision worker (`start-worker.sh`). Size to just saturate the Azure caps
`FORENSICS_WORKER_CONCURRENCY`	`0`	Prefork processes per forensics worker; 0 = one per CPU of the container's limit
`FAIR_SHARE_BUCKET_SIZE`	`5`	A company's tasks drop one priority level per this many outstanding tasks on a queue
`QUEUE_ALERT_OLDEST_WAITING_SECONDS`	`300`	The per-minute `queue_metrics` job logs a WARNING `queue_alert {json}` line when a queue's oldest waiting task is older than this; 0 = off
`USAGE_RECONCILIATION_HOUR_UTC`	`2`	Hour (UTC) of the nightly usage-counter reconciliation (Celery beat)

Variable	Default	Purpose
`STUCK_DOCUMENT_PENDING_MINUTES` / `STUCK_DOCUMENT_PROCESSING_MINUTES`	`10` / `30`	Stuck-document recovery (every 5 minutes, `app/tasks/stuck_documents_task.py`): a document still `pending` after this long, or `processing` with no update for this long, **while the extraction queue is empty and idle**, lost its tasks (Redis restart/outage) and is queued again. `0` disables that half
`STUCK_DOCUMENT_MAX_REQUEUES`	`3`	Re-queues per document (counted from its `document_requeued` audit rows) before it is marked `failed` with an explanation
`STUCK_DOCUMENT_BATCH_SIZE`	`200`	Most documents re-queued per run
`LOGIN_MAX_FAILED_ATTEMPTS` / `LOGIN_LOCKOUT_MINUTES`	`5` / `15`	Sign-in throttling (`app/services/login_throttle.py` , Redis): after this many failed sign-ins for one email address, it is refused (HTTP 429 + `Retry-After`) for this many minutes. Counted per address (unknown addresses too), cleared by a successful sign-in. `0` disables
`LOGIN_MAX_ATTEMPTS_PER_IP_PER_MINUTE`	`20`	Sign-in attempts of any outcome per client IP per minute (best effort: behind the proxy chain a client can influence `X-Forwarded-For`). `0` disables. Both limits fail open if Redis is unreachable
`SEED_ADMIN_EMAIL` / `SEED_ADMIN_PASSWORD`	`admin@example.com` / `ChangeMe123!`	Read by `seed.py` (not by the app): the platform admin it creates when the account does not exist. An existing account is left unchanged unless `seed.py --reset` is run. Set both in production: outside local/test, `seed.py` refuses to create or reset the admin with the default password or one under 12 characters (an existing admin is never touched)
`CELERY_POOL`	per queue	Read by `start-worker.sh` : overrides the pool type (`threads` for extraction/vision, `prefork` for forensics)
`CELERY_BEAT_SCHEDULE_FILE`	`/tmp/celerybeat-schedule`	Read by `start-beat.sh` (beat + the one-slot worker for `housekeeping_queue`)
`ISSUER_FUZZY_MATCH_THRESHOLD`	`85.0`	rapidfuzz WRatio score (0–100) an extracted issuer must reach to match the registry (05)
`METADATA_FORENSICS_MOD_DATE_THRESHOLD_SECONDS`	`1.0`	Jitter tolerance before "modified after created" flags (06)
`METADATA_FORENSICS_EDITING_SOFTWARE_NAMES`	`photoshop,gimp,illustrator,affinity,coreldraw,paint.net,pixlr,canva,inkscape`	Comma-separated, case-insensitive substrings that mark a Producer/Creator as an editing tool

Variable	Default	Purpose
`METADATA_FORENSICS_PDF_EDITOR_NAMES`	`ilovepdf,smallpdf,sejda,pdfescape,pdf-xchange editor,phantompdf,foxit pdf editor,nitro pro,nitro pdf pro,pdfelement,soda pdf,sodapdf,pdffiller,dochub,pdfcandy,pdf candy`	Same, for PDF editors (online and desktop); weighted lower than image editors
`DUPLICATE_HASH_HAMMING_THRESHOLD`	`5`	Max pHash Hamming distance (0–64) for a near-duplicate (10)

Risk **weights, severities and tier thresholds are not environment variables** — they live in the database, per company, and are edited in Settings › Risk Rules (and the platform template under Platform › Rule templates; see 11).

Backend — declared but UNUSED (do not need a value)

Variable	Would be for	Status
`AZURE_AI_VISION_ENDPOINT`, `AZURE_AI_VISION_KEY`	Signature/stamp detection, logo matching	Never read — detection uses the Azure OpenAI vision model
`AI_CONTENT_DETECTION_ENDPOINT`, `AI_CONTENT_DETECTION_KEY`	Content Safety / Hive	Never read — see 08
`EMAIL_SERVICE_CONNECTION_STRING`, `EMAIL_FROM_ADDRESS`	Transactional email	Never read — notifications are not built
`API_V1_PREFIX` (`/api/v1`)	URL prefix	Never read — routes have no prefix
`REDIS_URL`	Redis	Never read — Celery, the rate limiter, the fair-share counters and the queue monitor all use `CELERY_BROKER_URL`

docker-compose (optional overrides)

Read by `docker-compose.yml` from the shell or a root `.env`; defaults shown.

Variable	Default	Purpose
`POSTGRES_USER` / `POSTGRES_PASSWORD` / `POSTGRES_DB`	`docauth` / `docauth` / `docauth`	Postgres container credentials. If you change them, update `DATABASE_URL` to match
`POSTGRES_PORT`	`5432`	Host port
`REDIS_PORT`	`6379`	Host port
`PGBOUNCER_PORT`	`6432`	Host port of PgBouncer (`pgbouncer/pgbouncer.ini`, `pgbouncer/userlist.txt` — dev passwords only)
`FORENSICS_WORKER_CPUS`	`2`	CPUs per `forensics-worker` replica (`--profile workers`)

Frontend

Variable	Default	Purpose
`VITE_API_BASE_URL`	`/api`	Base URL the SPA calls (build time). The default relies on a proxy that maps `/api/*` → the API with the prefix stripped — the Vite dev server locally, the ingress in production (production-deployment.md). Setting it to a different origin instead requires CORS on the backend, which currently has **no** CORS middleware

No other frontend variables exist. The session is an in-memory access token plus an httpOnly refresh cookie (authentication) — nothing in `localStorage`.

Secrets checklist

`AZURE_STORAGE_CONNECTION_STRING`, `AZURE_DOCUMENT_INTELLIGENCE_KEY`, `AZURE_OPENAI_KEY`, `JWT_SECRET_KEY`, the owner database password (in `DATABASE_URL`), `DATABASE_APP_PASSWORD`, `DATABASE_PLATFORM_PASSWORD` and `SEED_ADMIN_PASSWORD` are the secrets (plus PgBouncer's `userlist.txt`). Keep them out of the repo (`.env` is git-ignored) and, on Azure, in Key Vault referenced from the container apps (see production-deployment.md).